

100 Days of Azure DevOps

Day 62 Handout — Role + assignee + scope — Owner at subscription is blast radius, not speed

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — built-in roles at RG scope (same assignee, different blast)

Role	Can	Cannot
Reader	List/read resources in scope	PUT/PATCH/DELETE; cannot grant roles
Contributor	Create/change/delete resources in scope	Grant roles (not Owner). Cannot always do data-plane secrets without extra roles
Owner	Contributor plus assign roles. The flamethrower	Escape the tenant. Still not 'God' over another directory
User Access Administrator	Assign roles only	A substitute for Contributor. Different job
Custom role	Actions[] you list. Last mile when built-ins are too wide/narrow	A lab toy for a Reader test

Architecture B — decide scope before you pick a friendly role name

Constraint	Default	Reject
Lab pipeline / human	Contributor or Reader on one RG	Owner on the subscription 'so we are not blocked'
Look but not touch	Reader on rg-day62	Contributor because the Portal was easier
Grant roles	Owner or User Access Admin at the smallest scope that works	Subscription Owner for a hello assignment
Custom role	Skip today	Inventing Microsoft.Authorization/roleDefinitions for fun
Data plane	Key Vault data-plane roles are extra (Day 64 Secrets User)	Assuming Contributor reads KV secrets — it does not under RBAC vaults

Architecture C — pitfalls that turn 'just Owner' into a delete that went wide

Pitfall	What you see	Fix
Subscription Owner for a pipeline	SPN can grant itself more and delete the sub's RGs	RG-scoped Contributor; no role-assignment permission
Wrong assignee	Assignment on a user you are not; or on the app object vs SP	Assign to the service principal object ID / UPN you intend
Scope typo	Role assigned, Portal still denies	scope must be the RG/resource ID, not a display name
Classic admins folklore	Co-admin from ASM era still lurking	Literacy: prefer Azure RBAC. Do not add classic admins
Leaving the test assignment	Reader leftover you forget	az role assignment delete when the proof is done (or keep Reader on a dedicated lab RG)

One-liner to remember

Owner is a flamethrower; prefer Reader/Contributor scoped to the resource group, not the subscription. Scope is the verb people skip.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal subscription. rg-day62. Assign to your user UPN, not an employer group. Azure CLI on the personal machine.

- 1 az group create -n rg-day62 -l eastus. Write the resource ID: /subscriptions/<sub>/resourceGroups/rg-day62.
- 2 az role assignment create --assignee <your-upn> --role Reader --scope that RG ID. az role assignment list --scope ... -o table.
- 3 Compare in notes: Reader vs Contributor vs Owner in one paragraph you could say out loud. Do not assign yourself Owner on the subscription to 'feel the difference'.
- 4 Optional proof: with only Reader, a write should fail (or reason about it if you also have higher roles inherited from the subscription — then say so honestly).
- 5 Note: Contributor does not grant Key Vault Secrets User on an RBAC vault. That surprise is Day 64.
- 6 Remove the extra assignment if it is noise, or keep Reader on rg-day62 as the muscle memory. Write docs/rbac-day62.md. No work-tenant screenshots.

Starter CLI — Reader on one RG, not Owner on the sub

```
az group create -n rg-day62 -l eastus
SUB=$(az account show --query id -o tsv)
SCOPE=/subscriptions/$SUB/resourceGroups/rg-day62
az role assignment create --assignee <your-upn> --role Reader --scope $SCOPE
az role assignment list --scope $SCOPE -o table
# Contributor = change resources, not grant roles
# Owner = includes Microsoft.Authorization/roleAssignments/write (flamethrower)
```

Done checklist

- Can recite role + assignee + scope as the triple
- Reader assignment on a lab RG exists or existed with a CLI receipt
- Will not recommend subscription Owner for a pipeline
- Knows Contributor ≠ Key Vault secret read on RBAC vaults

Tomorrow — Day 63

Service connections and service principals — robot badges, not master keys